Theory : Security FrameworksOverview of NIST, ISO 27001, and CIS Controls. Map security measures to a given framework.

Tasks :-

1.Pick any one app you use daily (such as Instagram, Zomato, or PhonePe) and list 5 security measures it likely uses to protect user data.

Ans :-

- **Security Measures PhonePe Likely Uses**

1. End-to-End Encryption (TLS/SSL)

- All communication between your device and PhonePe's servers is encrypted using HTTPS/TLS.
- Your UPI PIN, bank details, and transaction data are scrambled in transit.
- Even if someone intercepts the traffic on public Wi-Fi, they cannot read it.
- PhonePe uses 256-bit encryption, the same standard used by banks.

2. UPI PIN & Two-Factor Authentication (2FA)

- Every transaction requires:
- Your UPI PIN (a 4–6 digit secret known only to you).
- Often an OTP sent to your registered mobile number for verification.
- This ensures that even if someone gets your phone, they cannot complete a transaction without your PIN.

3. Device Binding & SIM Verification

- PhonePe binds your account to:
- Your specific device (IMEI/device fingerprint).
- Your SIM card linked to your registered mobile number.
- If someone tries to log in from a new device, additional verification (OTP) is triggered.

**2.Choose either the NIST Cybersecurity Framework, ISO 27001, or CIS Controls. For each of the 5 security measures you listed in the previous task, map it to the most relevant category or control in your chosen framework.

Hint: For example, 'two-factor authentication' might map to 'Access Control' in CIS or 'Protect' in NIST.**

Ans :-

- **Selected Framework: NIST Cybersecurity Framework (CSF)**
- **Application:** PhonePe

No.	Security Measure	NIST CSF Category	Purpose
1	**Encryption**	Protect (PR.DS – Data Security)	Protects sensitive user data from unauthorized access.
2	**OTP Verification**	Protect (PR.AA – Identity Management, Authentication, and Access Control)	Verifies the user's identity during login or sensitive activities.
3	**MPIN Protection**	Protect (PR.AA – Identity Management, Authentication, and Access Control)	Prevents unauthorized UPI transactions.
4	**Two-Factor Authentication (2FA)**	Protect (PR.AA – Identity Management, Authentication, and Access Control)	Adds an extra layer of account security.
5	**Fraud Detection**	Detect (DE.CM – Continuous Monitoring)	Identifies suspicious transactions and unusual activities.

3.Given this scenario: A new food delivery app wants to prevent unauthorized access, protect payment info, and ensure customer privacy. Select 3 controls from the CIS Controls framework that would address these concerns and explain how each control helps.

Ans :-

No.	CIS Control	How It Helps
1	CIS Control 5: Account Management	Creates, manages, and removes user accounts properly to prevent unauthorized access.
2	CIS Control 6: Access Control Management	Uses role-based access control (RBAC) and least privilege to ensure users and employees can access only the data they need.
3	CIS Control 3: Data Protection	Protects customer and payment information using encryption, secure storage, and data access restrictions.

**4.Create a comparison table with three columns (NIST, ISO 27001, CIS Controls) and list 3 unique features or strengths of each framework based on your research.

Hint: Focus on what makes each framework different or especially useful for certain organizations.**

Ans :-

NIST Cybersecurity Framework	ISO 27001	CIS Controls
1. Provides a flexible, risk-based approach to managing cybersecurity risks.	1. Provides an internationally recognized standard for Information Security Management Systems (ISMS).	1. Provides a prioritized set of practical cybersecurity safeguards.
2. Uses six functions: Govern, Identify, Protect, Detect, Respond, and Recover.	2. Supports formal certification through independent audits.	2. Focuses on actionable technical security measures to reduce common cyber threats.
3. Suitable for organizations of different sizes and industries, especially for improving cybersecurity maturity.	3. Emphasizes continuous improvement, risk assessment, and information security policies.	3. Provides implementation groups (IG1, IG2, IG3) to help organizations prioritize controls according to their resources and risk.

5.Use ChatGPT or another AI tool to generate a checklist of 5 security actions a small e-commerce startup should take according to the ISO 27001 framework. Copy the AI's response and briefly comment on whether you agree with each item and why.

Ans :-

- **Security Actions According to ISO 27001 :-**

1. **Access Control:**Implement strong passwords, multi-factor authentication (MFA), and role-based access control to prevent unauthorized access.

2. **Data Encryption:**Encrypt sensitive customer information, payment-related data, and communications using secure encryption protocols.
3. **Regular Risk Assessment:** Identify potential cybersecurity threats, evaluate risks, and implement appropriate security measures.

4. **Data Backup and Recovery:** Perform regular backups of important business data and test recovery procedures to prevent data loss.

5. **Security Awareness Training:** Train employees to recognize phishing attacks, malware, suspicious emails, and other cybersecurity threats.

- **My Comments and Agreement**

No.	Security Action	My Opinion	Reason
1	Access Control	Agree	It prevents unauthorized users from accessing customer and business accounts.
2	Data Encryption	Agree	It helps protect sensitive customer and payment information from exposure.
3	Regular Risk Assessment	Agree	It helps identify vulnerabilities and reduce security risks before incidents occur.
4	Data Backup and Recovery	Agree	It helps restore important business data after accidental deletion, system failure, or cyberattacks.
5	Security Awareness Training	Agree	It helps employees identify phishing emails and avoid common security mistakes.